Segurança em Redes de Comunicações

Introduction to Firewall Deployment

iptables (nf_tables)

If the local/frrouting docker image is not available in your setup, do:

With the provided Dockerfile, create a custom docker image:

```
$ docker build -t local/frrouting -f Dockerfile_frrouting .
```

Add the Docker container to GNS3 as template:

- Choosing an existing image;
- Define it as local/frrouting container image;
- Activate 4 network interfaces (adapters), and
- **Add the following directories as permanent in the advanced tab:**

```
/etc/frr/
/etc/conntrackd
/etc/init.d/
```

Note: FRRouting image is a linux container with a set of services/protocols installed that enable advance network features. The command vtysh provides a Cisco-like CLI.

If the local/pcclient docker image is not available in your setup, do:

With the provided Dockerfile, create a custom docker image:

```
$ docker build -t local/pcclient -f Dockerfile_pcclient .
```

Add the Docker container to GNS3 as template:

- Choosing an existing image;
- Define it as local/pcclient container image;
- Activate 1 network interface (adapter), and
- **Add the following directories as permanent in the advanced tab:**

```
/etc/wpa_supplicant/
/etc/init.d/
```

If the local/server docker image is not available in your setup, do:

With the provided Dockerfile, create a custom docker image:

```
$ docker build -t local/server -f Dockerfile_server .
```

Add the Docker container to GNS3 as template:

- Choosing an existing image;
- Define it as local/server container image;
- Activate 1 network interface (adapter), and
- **Add the following directories as permanent in the advanced tab:**

```
/etc/init.d/
```

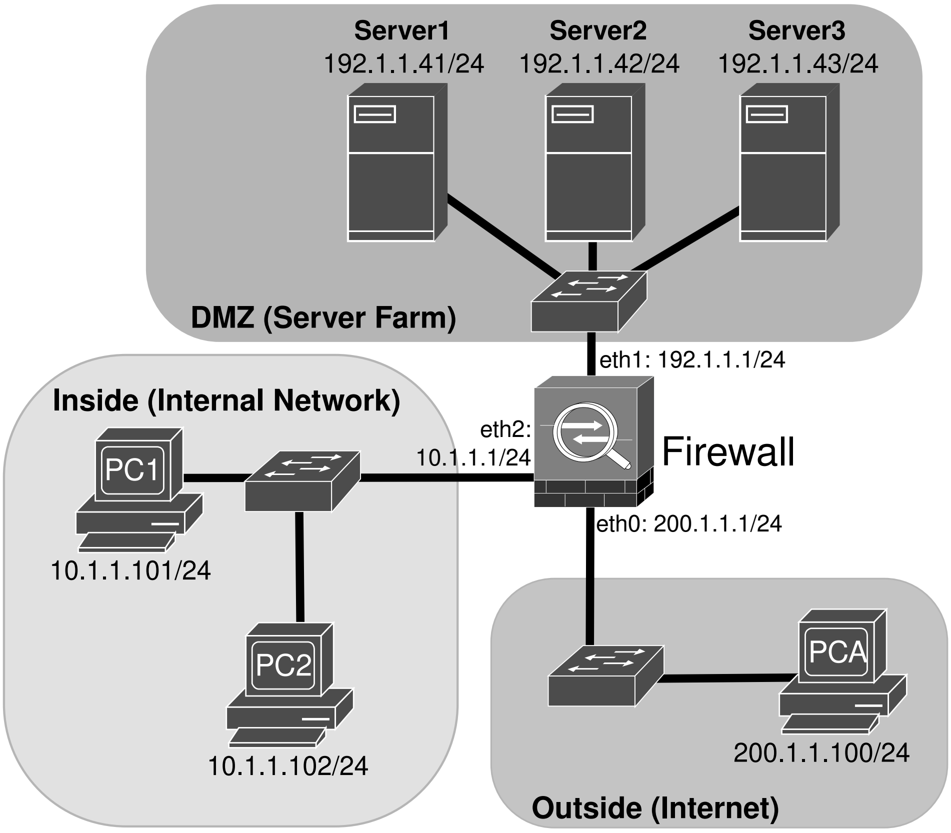
Linux Firewall Deployment

1. Configure the network depicted in the following figure using GNS3 with PC1, PC2 and PCA as local/pcclient docker, the DMZ server as a local/server docker, and the Firewall as a local/ffrouting docker with iptables and conntrackd installed. Configure PCs , Servers and Firewall addresses and gateways.

>> Test connectivity between all devices with ping commands.

Do not proceed if full connectivity is not possible!

iptables manual: https://linux.die.net/man/8/iptables



2. Using socat, create multiple message echo services, using TCP or UDP, and various ports.

At Server 1:

TCP port 9001:

```
socat -d2 TCP-LISTEN:9001,reuseaddr,fork SYSTEM:'while read msg; do echo "Server reply: $msg"; done' &
```

UDP port 9001:

```
socat -d2 UDP-LISTEN:9001,reuseaddr,fork SYSTEM:'while read msg; do echo "Server reply: $msg"; done' &
```

At Server 2:

TCP port 9002:

```
socat -d2 TCP-LISTEN:9002,reuseaddr,fork SYSTEM:'while read msg; do echo "Server reply: $msg"; done' &
```

TCP port 9012:

```
socat -d2 TCP-LISTEN:9012,reuseaddr,fork SYSTEM:'while read msg; do echo "Server reply: $msg"; done' &
```

At Server 3:

TCP port 9001:

```
socat -d2 TCP-LISTEN:9001,reuseaddr,fork SYSTEM:'while read msg; do echo "Server reply: $msg"; done' &
```

TCP port 9002:

```
socat -d2 TCP-LISTEN:9002,reuseaddr,fork SYSTEM:'while read msg; do echo "Server reply: $msg"; done' &
```

To see system’s open ports, use:

```
netstat -lnutp
```

>> What can you conclude from the netstat command outputs?

Only if required, to stop all `socat` server instances, use:

```
killall socat
```

3. Start a Wireshark capture on the link between the Firewall and DMZ Switch.

Fom PC1, PC2 and PCA, test all services/protocols/ports:

```
socat - TCP:192.1.1.41:9001
socat - UDP:192.1.1.41:9002
socat - TCP:192.1.1.42:9002
socat - TCP:192.1.1.42:9012
socat - TCP:192.1.1.43:9001
socat - TCP:192.1.1.43:9002
```

Using all services, send multiple messages and wait for the echo responses.

Do not proceed if some service is not responding!

From PC1, try to contact non-available services, in other ports:

```
socat - TCP:192.1.1.41:8001
socat - UDP:192.1.1.41:8001
```

From PCA, make a TCP and UDP port scan to all DMZ servers (port range 9001-9012):

```
nmap -sS -n 192.1.1.41-43 -p 9001-9012
nmap -sU -n 192.1.1.41-43 -p 9001-9012
```

>> What can you observe on the Wireshark capture?

>> What can you observe on Serves services log outputs?

>> What protocols and ports are being used for the messages exchange?

>> What are the differences between UDP and TCP exchanges, specifically at the beginning?

>> What are the differences when contacting a closed UDP port and a closed TCP port?

4. Configure the firewall NAT/PAT mechanisms. Assume that the network will use the IPv4 public address 192.0.0.100 to 192.0.0.110:

```
iptables -t nat -A POSTROUTING -j SNAT -o eth0 -s 10.0.0.0/8 --to 192.0.0.100-192.0.0.110
```

Verify the applied rules:

```
iptables -t nat -L -vn
```

>> Start a capture on the link between the firewall (eth0) and the OUTSIDE switch. Ping PCA from PC1/PC2 and verify the correct translation of the source IPv4 addresses.

>> Use the following command to verify the active NAT translations: `conntrack -L -n`

ipables short manual:

To save iptables rules use:

```
iptables-save > /etc/init.d/iptables.rules
```

To restore iptables rules use:

```
iptables-restore < /etc/init.d/iptables.rules
```

To create a new chain use option: `-N <chain>`.

To delete a complete chain use option: `-X <chain>`. Must not be referenced in other chains.

To Append a rule to the end use option `-A <chain>`.

To Insert a rule in line x, use option: `-I <chain> x`.

To delete an entry in line x, use option: `-D <chain> x`.

Examples:

```
iptables -N ZONE-OUTSIDE
iptables -X ZONE-OUTSIDE
iptables -A ZONE-OUTSIDE ...
(insert in line 10) iptables -I ZONE-OUTSIDE 10 ...
(delete line 10) iptables -D ZONE-OUTSIDE 10 …
```

5. At the Firewall, define (i) the default policy for FORWARD chain to DROP and (ii) network security zones associated with respective network interface(s):

```
iptables -P FORWARD DROP

iptables -N ZONE-INSIDE
iptables -A FORWARD -o eth2 -j ZONE-INSIDE
iptables -N ZONE-DMZ
iptables -A FORWARD -o eth1 -j ZONE-DMZ
iptables -N ZONE-OUTSIDE
iptables -A FORWARD -o eth0 -j ZONE-OUTSIDE
```

To verify the zone policies, firewall rules and statistics use the following commands:

```
iptables -L -vn
iptables -L -vn --line-numbers
iptables -S
```

>> Test the full (or lack of) connectivity between all network equipment (and IPv4 addresses). Explain the results.

6. Create and configure the firewalls chains and rules to allow the Inside devices to ping all Outside devices:

```
iptables -N FROM-INSIDE-TO-OUTSIDE
iptables -A FROM-INSIDE-TO-OUTSIDE -p icmp --icmp-type echo-request -j ACCEPT

iptables -N TO-INSIDE
iptables -A TO-INSIDE -m state --state ESTABLISHED -j ACCEPT

iptables -A ZONE-OUTSIDE -i eth2 -j FROM-INSIDE-TO-OUTSIDE

iptables -A ZONE-INSIDE -j TO-INSIDE
```

To verify the zone policies, firewall rules and statistics use the following commands:

```
iptables -L -vn
iptables -L -vn --line-numbers
```

>> Test the implemented rules, pinging the DMZ Servers and PC2 from PC1.

>> What alternative can be used appending rules (-A) to the end of the chain?

7. Configure the firewalls chains and rules to allow the Inside zone devices to ping all DMZ (network 192.1.1.0/24) devices:

```
iptables -N FROM-INSIDE-TO-DMZ
iptables -A FROM-INSIDE-TO-DMZ -d 192.1.1.0/24 -p icmp --icmp-type echo-request -j ACCEPT

iptables -A ZONE-DMZ -i eth2 -j FROM-INSIDE-TO-DMZ
```

Note: The chain TO-INSIDE was already defined before.

To verify the zone policies, firewall rules and statistics use the following commands:

```
iptables -L -vn
iptables -L -vn --line-numbers
```

>> Test the implemented rules, pinging from PC1, PC2 and PCA all DMZ Servers (192.1.1.41 to 192.1.1.43). Explain the results obtained.

>> Test the implemented rules, pinging from all DMZ Servers both internal PCs (10.1.1.101 and 10.1.1.102). Explain the results obtained.

8. Configure the firewalls chains and rules to allow the Outside zone devices to ping only the DMZ Server1 (only IP address 192.1.1.41):

```
iptables -N FROM-OUTSIDE-TO-DMZ
iptables -A FROM-OUTSIDE-TO-DMZ -d 192.1.1.41 -p icmp --icmp-type echo-request -j ACCEPT

iptables -N FROM-DMZ-TO-OUTSIDE
iptables -A FROM-DMZ-TO-OUTSIDE -m state --state ESTABLISHED -j ACCEPT

iptables -A ZONE-DMZ -i eth0 -j FROM-OUTSIDE-TO-DMZ
iptables -A ZONE-OUTSIDE -i eth1 -j FROM-DMZ-TO-OUTSIDE
```

To verify the zone policies, firewall rules and statistics use the following commands:

```
iptables -L -vn
iptables -L -vn --line-numbers
```

>> Test the implemented rules, pinging from PCA all DMZ Servers (192.1.1.41 to 192.1.1.43). Explain the results obtained.

>> Test the implemented rules, pinging from all DMZ Servers the external device PCA (200.1.1.100). Explain the results obtained.

9. Add a new rule to the chain FROM-OUTSIDE-TO-DMZ to allow the Outside zone devices to access TCP service in port 9001 of DMZ Server 1 (only IP address 192.1.1.41):

```
iptables -A FROM-OUTSIDE-TO-DMZ -d 192.1.1.41 -p tcp --dport 9001 -j ACCEPT
```

To verify the zone policies, firewall rules and statistics use the following commands:

```
iptables -L -vn
iptables -L -vn --line-numbers
```

>> Test the implemented rules, connecting the services with TCP and UDP to port 9001 from the PCA the Servers 1 and 3 (192.1.1.41 and 192.1.1.43). What can you conclude?

Use the commands:

```
socat - TCP:192.1.1.41:9001
socat - TCP:192.1.1.43:9001
socat - UDP:192.1.1.41:9001
socat - UDP:192.1.1.43:9001
```

>> From PCA, test the connectivity with the other servers' services, with other UDP/TCP ports. What can you conclude?

>> From PCA, make a TCP and UDP port scan of all DMZ servers (port range 9001-9012). What can you conclude?

Use the commands:

```
nmap -sS -n 192.1.1.41-43 -p 9001-9012
nmap -sU -n 192.1.1.41-43 -p 9001-9012
```

>> Add option “-Pn” to nmap commands and repeat scan. What can you conclude?

>> Fron the nmap output results, explain the difference between port states open, closed and filtered.

>> From PC1 and PC2, test the connectivity with servers’ services. What can you conclude?

>> Verify the iptables statistics (`iptables -L -vn`). What can you conclude about rule matching statistics?

10. Add a new rule to the chain FROM-OUTSIDE-TO-DMZ to allow the Outside zone devices to acceess (non-existing) UDP service in port 9011 of DMZ Server 1 (only IP address 192.1.1.41):

```
iptables -A FROM-OUTSIDE-TO-DMZ -d 192.1.1.41 -p udp --dport 9011 -j ACCEPT
```

>> From PCA, make an UDP port scan of DMZ Server1 (port range 9001-9012). Why UDP port 9011 still appears with state filtered and not closed?

Use the commands:

```
nmap -sU -n 192.1.1.41 -p 9001-9012
```

Add to chain FROM-DMZ-TO-OUTSIDE, the ACCEPT action when the connection state is RELATED.

```
iptables -A FROM-DMZ-TO-OUTSIDE -m state --state RELATED -j ACCEPT
```

>> From PCA, make again an UDP port scan of DMZ Server1 (port range 9001-9012). Explain the output differences (namelly, UDP port 9011 state).

11. Implement the security policy that allows: (i) Inside zone devices **can** access Server2 TCP services, and (ii) PC1 **cannot** access Server 2 service TCP 9002.

```
iptables -A FROM-INSIDE-TO-DMZ -d 192.1.1.42 -p tcp -j ACCEPT
iptables -A FROM-INSIDE-TO-DMZ -s 10.1.1.101 -d 192.1.1.42 -p tcp --dport 9002 -j DROP
```

Verify the iptables rule order for chain FROM-INSIDE-TO-DMZ:

```
iptables -L FROM-INSIDE-TO-DMZ -vn --line-numbers
```

From PC1 and PC2, test the connectivity with servers’ TCP services using nmap:

```
nmap -sS 192.1.1.42 -p 9001-901
```

>> Why the security policy is not correctly implemented?

>> Verify the iptables rule order and statistics (`iptables -L -vn --line-numbers`).

12. Change the order of the chain rules. Delete the more specfic rule, and insert it before the more generic one (at rule number 2):

```
iptables -D FROM-INSIDE-TO-DMZ -s 10.1.1.101 -d 192.1.1.42 -p tcp --dport 9002 -j DROP
iptables -I FROM-INSIDE-TO-DMZ 2 -s 10.1.1.101 -d 192.1.1.42 -p tcp --dport 9002 -j DROP
```

Verify the iptables rule order for chain FROM-INSIDE-TO-DMZ:

```
iptables -L FROM-INSIDE-TO-DMZ -vn --line-numbers
```

From PC1 and PC2, test the connectivity with servers’ TCP services using nmap:

```
nmap -sS 192.1.1.42 -p 9001-901
```

>> Why the security policy is now correctly implemented?

>> What can you conclude about the importance of rule order/precedence?

>> which rules should be first on the chain, m ore specfic or more generic?

13. Design a more complex security policy and implement it. For testing porpuses you can add more devices/servers. Considerer the following cases:

- An external device, after beeing identified as a malicious actor, it must be blocked from accessing any service/device.
- Servers must have access to Linux repositories to update OS.
- Some DMZ services are available only to internal, external, or both devices.
- Isolate a specific internal device/network from the rest of the network, cannot even use the Firewall as gateway.